UNIVERSITY OF MANNHEIM

Data and Web Science Group

IE500 Data Mining Student Project Proposal

Predicting Exploitation of Software Vulnerabilities

A Machine Learning Approach Using the CISA KEV Catalogue and NVD Dataset

Team number: Group 6

Team members:

bb84pebu - Dinara Anis

buenlue - Beyza Ünlü

js21kuki - Gül Duman

jkochari - Julia Kocharina

sopschoe - Sophie Schöneberg

Course: IE500 Data Mining

Date: October 2026

1. Introduction

Software vulnerabilities can pose security risks when attackers use them to gain access to systems, steal information, or disrupt services. Since thousands of vulnerabilities are reported every year, it is difficult for security teams to investigate and fix all of them at once. It is therefore important to identify which vulnerabilities are more likely to be exploited in real-world attacks.

The Common Vulnerability Scoring System (CVSS) is commonly used to assess the severity of vulnerabilities. However, a high severity score does not necessarily mean that a vulnerability will be exploited. This project investigates whether machine-learning models can predict exploitation more effectively than CVSS scores alone.

The project uses data from the National Vulnerability Database (NVD) and the CISA Known Exploited Vulnerabilities (KEV) Catalog. The NVD provides information about publicly known vulnerabilities, while the KEV Catalog lists vulnerabilities known to have been exploited in real-world attacks.

The main research question is whether machine-learning models can predict if a vulnerability will be added to the KEV Catalog within 90 days of publication more effectively than CVSS severity scores alone. The aim is to compare different approaches and investigate whether vulnerability characteristics can help improve the prioritization of vulnerabilities.

2. Background

The National Vulnerability Database (NVD) is run by the National Institute of Standards and Technology (NIST). The NVD gives organized data about cybersecurity vulnerabilities that are publicly known. Every vulnerability gets its Common Vulnerabilities and Exposures (CVE) identifier. The NVD also lists vulnerability descriptions, Common Vulnerability Scoring System (CVSS) scores, weakness classifications (CWE), and details on which vendors and products are affected. In this project, the NVD is the source of predictive features. These characteristics will be used to check whether vulnerability information can help predict whether a vulnerability will later appear in the CISA Known Exploited Vulnerabilities Catalog.

The Known Exploited Vulnerabilities (KEV) Catalog is kept by the Cybersecurity and Infrastructure Security Agency (CISA). The KEV Catalog lists vulnerabilities that are known to have been used in attacks. The KEV Catalog supplies CVE identifiers and the dates when each vulnerability was added. The KEV Catalog gives the outcome data for this project. By comparing vulnerability publication dates with the KEV addition dates, this project sets exploitation labels. A vulnerability gets a label if it appears in the KEV Catalog within 90 days of publication. Still, a vulnerability that is not in the KEV Catalog may still have been exploited.

The two sources give information. The NVD gives details about vulnerability characteristics, while the KEV Catalog shows which vulnerabilities have been exploited. Records from the NVD and the KEV Catalog are joined by CVE identifiers to build a dataset for classification. This lets the project see if vulnerability characteristics can separate vulnerabilities that are added to the KEV Catalog in the chosen prediction window from the ones that are not.

3. Background and Work Plan: Prediction Methodology

3.1 Related Work and Proposed Approach

Vulnerability prioritization is often based on severity scores such as CVSS, but a high severity score does not necessarily mean that a vulnerability will actually be exploited. Other approaches therefore focus more directly on exploitation likelihood rather than severity alone. Our project follows this general idea by using vulnerability information from the NVD together with labels

derived from the CISA KEV Catalog. The aim is to investigate which vulnerability characteristics are associated with exploitation shortly after publication in a clear data mining setting.

3.2 Target Definition

The prediction target will be defined using a fixed 90-day window after the publication date of each CVE. A vulnerability will be labeled as positive if it is added to the CISA KEV Catalog within 90 days after publication. CVEs that are not added within this period will form the negative class for the classification task.

Using a fixed time window gives all vulnerabilities the same observation period. The negative class should therefore be interpreted as not added to KEV within 90 days, rather than as evidence that the vulnerability was never exploited.

3.3 Feature Selection and Data Preparation

Candidate features will be derived from information available in the NVD, including CVSS v3.1 components, CWE categories, vendor and product information, CNA/source identifier, publication-related information, vulnerability descriptions, and reference-related features. The final feature set will depend on data coverage and on whether the information is available at the intended prediction point.

Missing values will be handled depending on the type and completeness of each variable. Features with very high missing rates may be excluded, while missing categorical values can be represented by an additional unknown category. Numerical missing values can be handled through an appropriate imputation method where necessary.

Special attention will be paid to data leakage. Variables that directly reveal KEV membership, such as CISA-related fields contained in the NVD, will not be used as predictors. References that directly link to CISA information and variables that may only become available after the intended prediction point will also be excluded. This is intended to ensure that the models learn from vulnerability characteristics rather than from information that already reveals the target.

4. Algorithms

We use the following algorithms:

- **Elastic-net logistic regression.** An interpretable linear reference that handles sparse TF-IDF features.
- **Random forest.** Captures interactions, for example, a CWE that matters only for some vendors. We tune the number of trees, minimum leaf size, and features per split.
- **Gradient boosting (LightGBM).** We tune the learning rate, number of leaves, and minimum child samples, with early stopping.

Class imbalance (0.33% positives) is handled with class weights (balanced, scale_pos_weight).

5. Evaluation Design and Metrics

Time-based folds. Random splits would let the model learn from CVEs published after the ones it is tested on, so we never use them. We use three folds: train 2022 test 2023 (121 positives); 2022-23 test 2024 (113 positives); 2022-24 test 2025 (159 positives). Tuning uses the last training year. The 2025 fold is run once, after all design decisions are frozen.

Metrics. Predicting "never exploited" reaches 99.7% accuracy, so accuracy is useless here. We evaluate rankings:

- **PR-AUC** (average precision), the main metric. Random ranking scores the base rate, about 0.003.
- **Precision@k and Recall@k** for a team with a fixed budget: k = top1% of the test year, and the top 50 per month.

References

- Github repository: https://github.com/Schoeneberg-Sophie/data-mining-project
- CISA. Known Exploited Vulnerabilities (KEV) Catalog. https://www.cisa.gov/known-exploited-vulnerabilities-catalog
- NIST. National Vulnerability Database (NVD). https://nvd.nist.gov/